

TASK 01: ADVANCED WEB DIRECTORY & PARAMETER DISCOVERY

The first task was to identify the Entry Points for a web application. Different tools can be used for finding hidden directories or for finding different hidden paths. The ffuf tool was used here as it is relatively fast compared to alternatives such as Dirbuster.

Tool: ffuf – Web Directory Fuzzer

The following command was used to discover hidden directories and files on the target:

```
ffuf -u https://hackthissite.org/FUZZ \  
-w /usr/share/wordlists/dirb/common.txt
```

Flag Reference

Flag	Name	Description
-u	Target URL	FUZZ marks the injection point – words from the wordlist are inserted here
-w	Wordlist	Provides the list of directory/file names to test (e.g. common.txt)
-fc 404	Filter Codes	Hides 404 Not Found responses – reduces noise in output significantly
-mc 200,301,302,403	Match Codes	Shows: 200 (exists), 301/302 (redirect), 403 (forbidden = high-value target)
-t 50	Threads (Speed)	50 concurrent requests – balances speed vs server stress (higher = faster)
-e .php,.html,.txt	Extensions	Appends extensions: tests admin.php, login.html, config.txt, etc.
-ac	Auto Filter	ffuf auto-calibrates and removes baseline/junk responses intelligently

Full optimized command used to get effective results:

```
ffuf -u https://hackthissite.org/FUZZ \  
-w /usr/share/wordlists/dirb/common.txt \  
-mc 200,301,302,403 -fc 404 -t 50 -e .php,.html,.txt -ac
```

```
(hyena@hyena) -[+]  
$ ffuf -u https://hackthissite.org/FUZZ -w /usr/share/wordlists/dirb/common.txt -fc 404 -mc 200,403,401  
  
v2.1.0-dev  
  
:: Method      : GET  
:: URL         : https://hackthissite.org/FUZZ  
:: Wordlist     : FUZZ: /usr/share/wordlists/dirb/common.txt  
:: Follow redirects : false  
:: Calibration : false  
:: Timeout      : 10  
:: Threads     : 40  
:: Matcher     : Response status: 200,403,401  
:: Filter      : Response status: 404  
  
[Status: 200, Size: 22985, Words: 2076, Lines: 292, Duration: 1362ms]  
cgi-bin/    [Status: 403, Size: 199, Words: 14, Lines: 8, Duration: 875ms]  
jquery     [Status: 200, Size: 94840, Words: 1234, Lines: 4, Duration: 1732ms]  
robots     [Status: 200, Size: 66, Words: 4, Lines: 4, Duration: 892ms]  
robots.txt [Status: 200, Size: 66, Words: 4, Lines: 4, Duration: 893ms]  
security   [Status: 200, Size: 361, Words: 36, Lines: 7, Duration: 921ms]  
:: Progress: [4614/4614] :: Job [1/1] :: 23 req/sec :: Duration: [0:02:38] :: Errors: 0 ::  
  
(hyena@hyena) -[+]  
$
```

Figure 1 – ffuf scan output showing discovered directories on hackthissite.org

The scan revealed several key paths including /robots.txt, /cgi-bin (403), /jquery, /security, and /robots.

Hidden Directory: robots.txt

The robots.txt file was identified as a hidden directory that often reveals sensitive data or common entry points into a web application. It was visited and found to contain the following disallow rules:

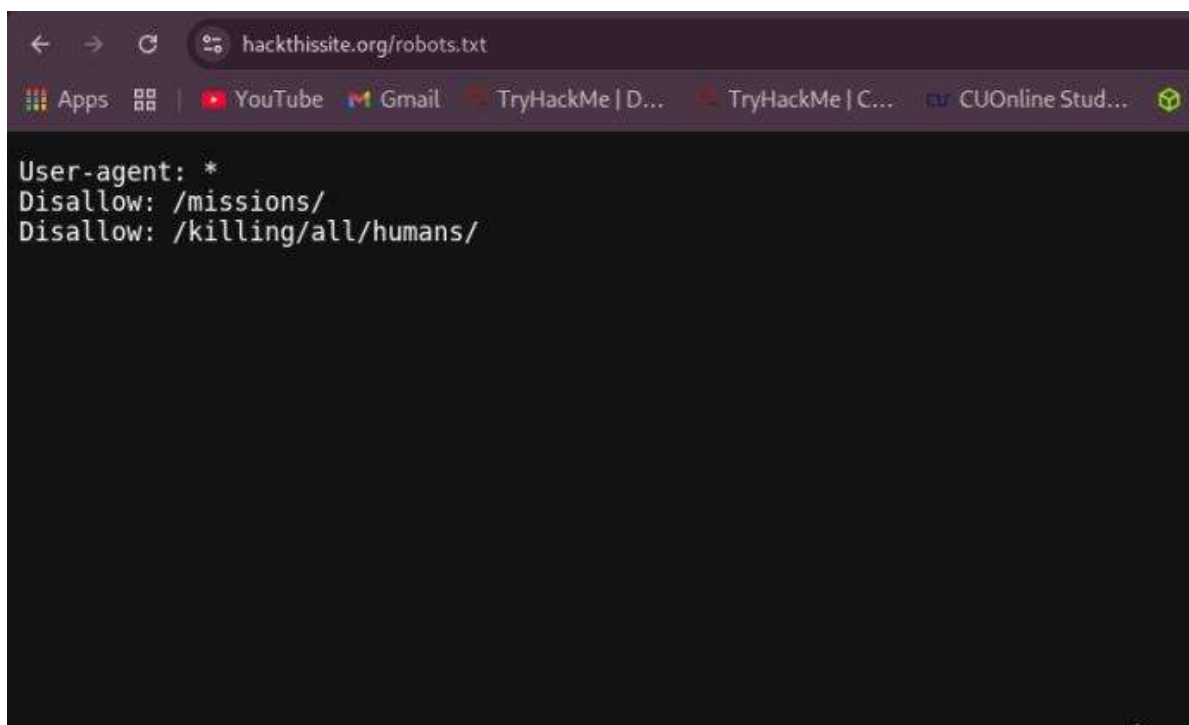


Figure 2 – robots.txt contents at hackthissite.org revealing disallowed paths /missions/ and /killing/all/humans/

Tool: Arjun – URL Parameter Discovery

After successfully finding hidden directories, Arjun was used to discover URL parameters such as ?id=, ?file=, and ?page= – common injection points where vulnerabilities like SQLi, LFI, and XSS often occur.

```
arjun -u http://www.itsecgames.com/ --stable
```

Here -u specifies the target page and --stable sets a conservative request speed. Arjun tests many possible parameters and shows which ones exist, helping find inputs like ?id= or ?file= where vulnerabilities often occur.



Figure 3 – Arjun parameter discovery scan output; no parameters were discovered on this endpoint

